

ACTIVE DIRECTORY KERBEROASTING

Detection Lab

SOC Detection Engineering Report

Prepared by: Vijay S

GitHub: github.com/JacobVijay26/Vijay_cybersecurity

Date: July 10, 2026

1. Objective

This lab simulates and detects a Kerberoasting attack within a self-hosted Active Directory environment. Kerberoasting is a common post-compromise attack technique in which an adversary with any valid domain account requests Kerberos service tickets (TGS) for accounts with Service Principal Names (SPNs), then attempts to crack the extracted ticket offline to recover the service account's plaintext password. The goal of this project is to:

- Build a realistic, isolated Active Directory lab environment
- Create a Kerberoastable service account (a common real-world misconfiguration)
- Execute a live Kerberoasting attack using industry-standard tooling (Impacket)
- Build a Splunk-based detection capability using Windows Security Event ID 4769
- Produce a working dashboard and scheduled alert for ongoing monitoring

2. Lab Environment

2.1 Architecture

- Domain Controller (DC01): Windows Server 2022 Standard, promoted to AD DS, hosting DNS for labcorp.local
- Domain Workstation: Windows 11 Enterprise, domain-joined to labcorp.local
- Attacker Machine: Kali Linux 2025.4 (Impacket toolset)
- SIEM: Splunk Enterprise 10.4.0, running on the host machine
- Network: VMware Workstation, isolated host-only network (VMnet1), subnet 192.168.100.0/24

2.2 IP Addressing

Host	Role	IP Address
DC01	Domain Controller / DNS	192.168.100.10
Windows 11	Domain-joined workstation	192.168.100.20
Kali Linux	Attacker machine	192.168.100.129 (DHCP)
Splunk Host	SIEM / Indexer	192.168.100.1

2.3 Architecture Diagram

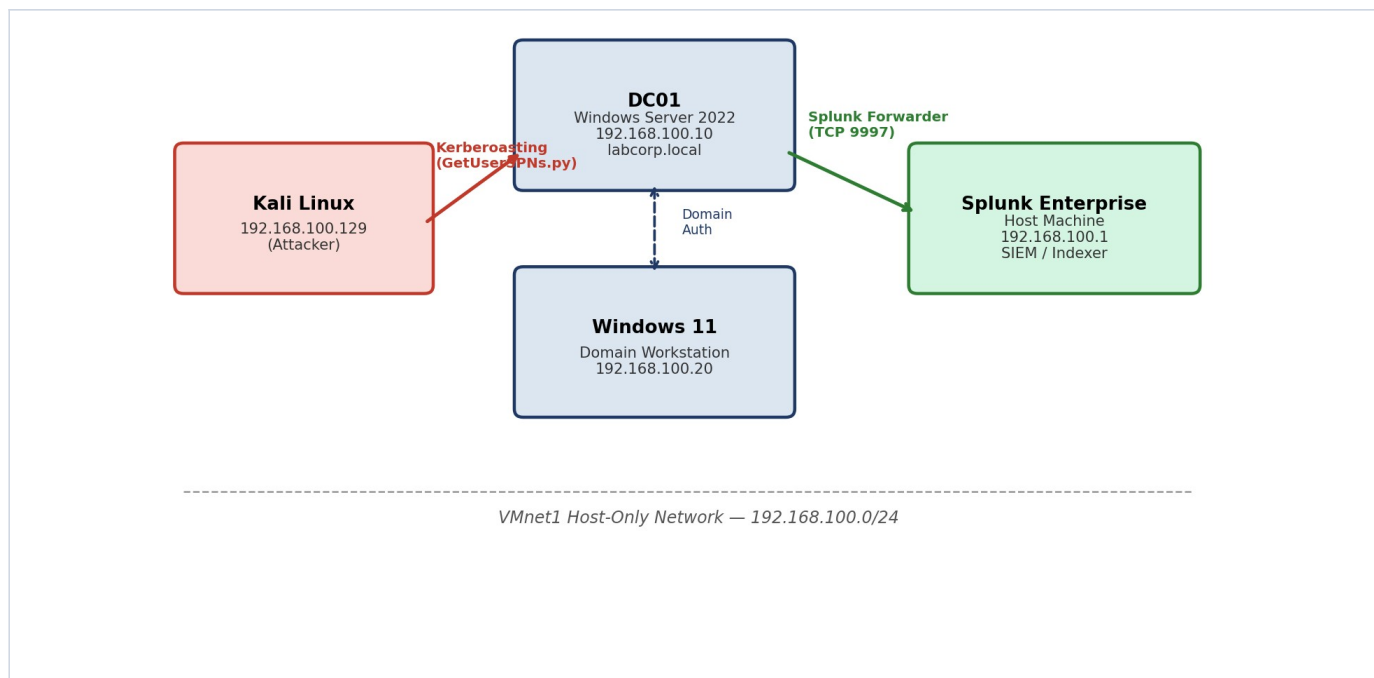


Figure 0: Lab network architecture — attack path (red) and telemetry forwarding path (green).

2.4 MITRE ATT&CK Mapping

This attack maps to MITRE ATT&CK technique T1558.003 (Steal or Forge Kerberos Tickets: Kerberoasting), under the Credential Access tactic. Mapping detections to ATT&CK provides a common reference point for SOC teams to reason about coverage and prioritize detection engineering work.

2.5 Domain Accounts Created

- janalyst — standard low-privilege domain user (simulated compromised account used to launch the attack)
- svc_sql — service account with SPN MSSQLSvc/dc01.labcorp.local:1433 registered (the Kerberoastable target, mimicking a common real-world SQL Server misconfiguration)

3. Infrastructure Build

Windows Server 2022 was installed on a dedicated VM, configured with a static IP, renamed to DC01, and promoted to the first Domain Controller of a new forest, labcorp.local.

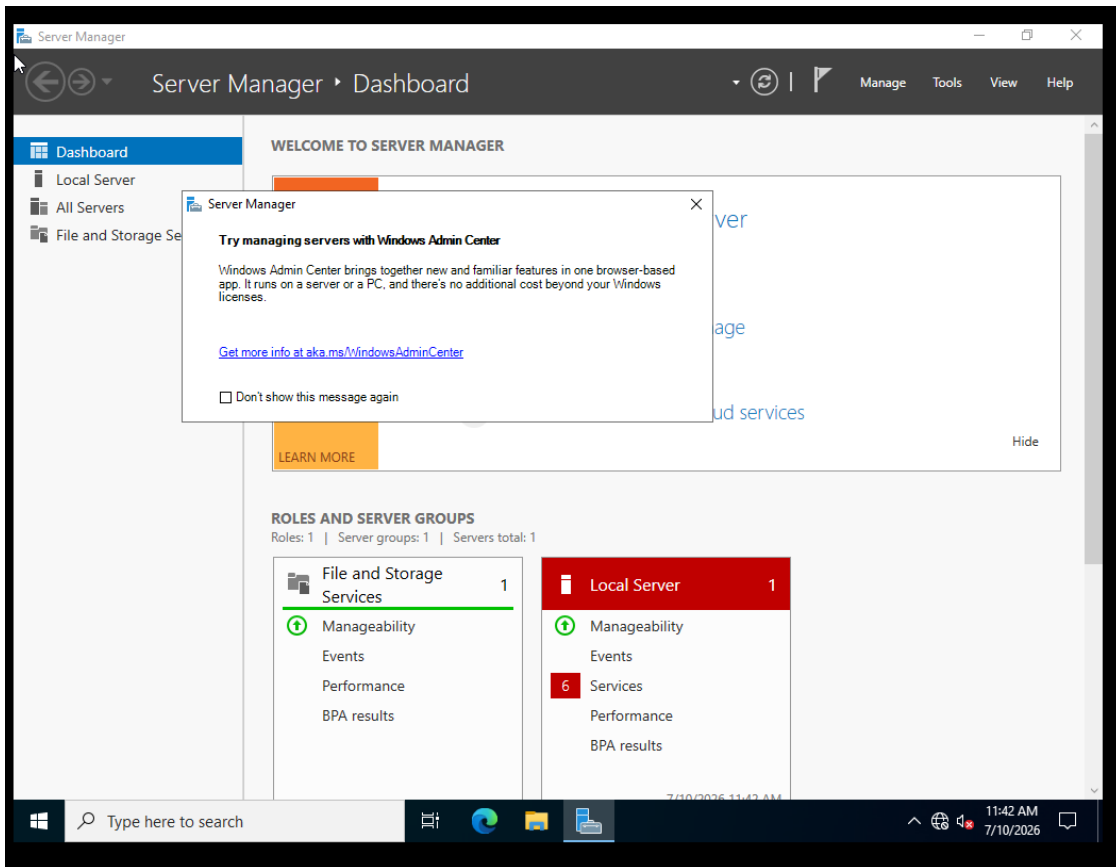


Figure 1: Windows Server 2022 installed and running Server Manager.

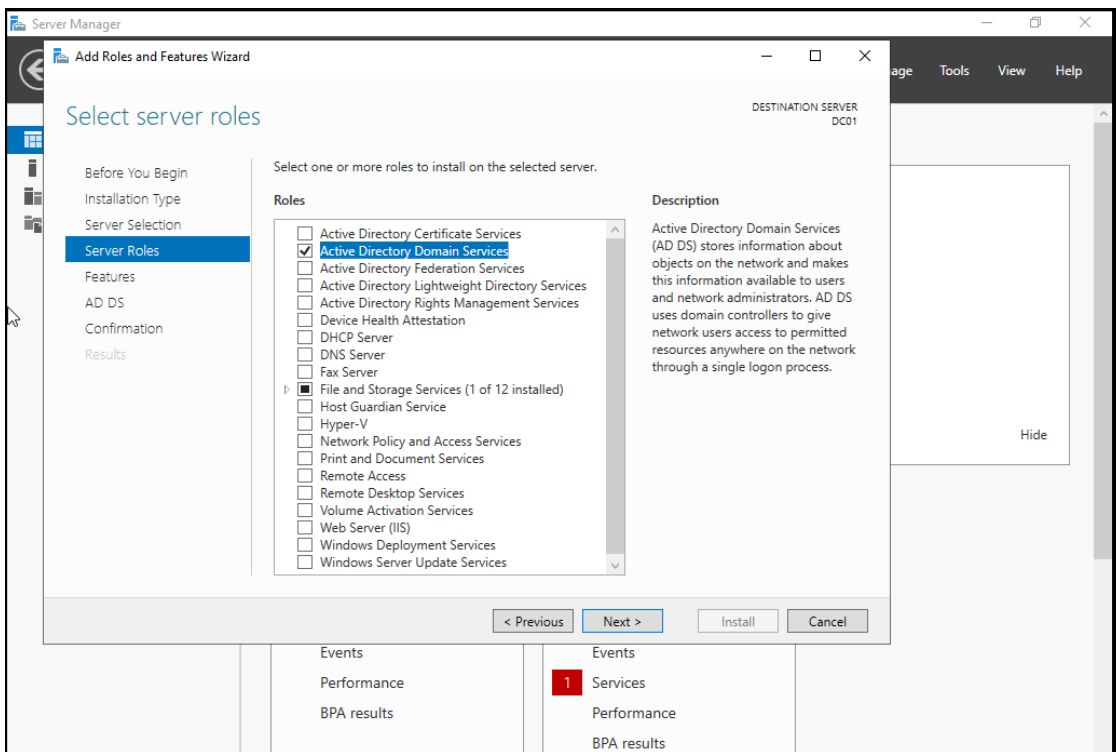


Figure 2: Active Directory Domain Services role selected for installation.

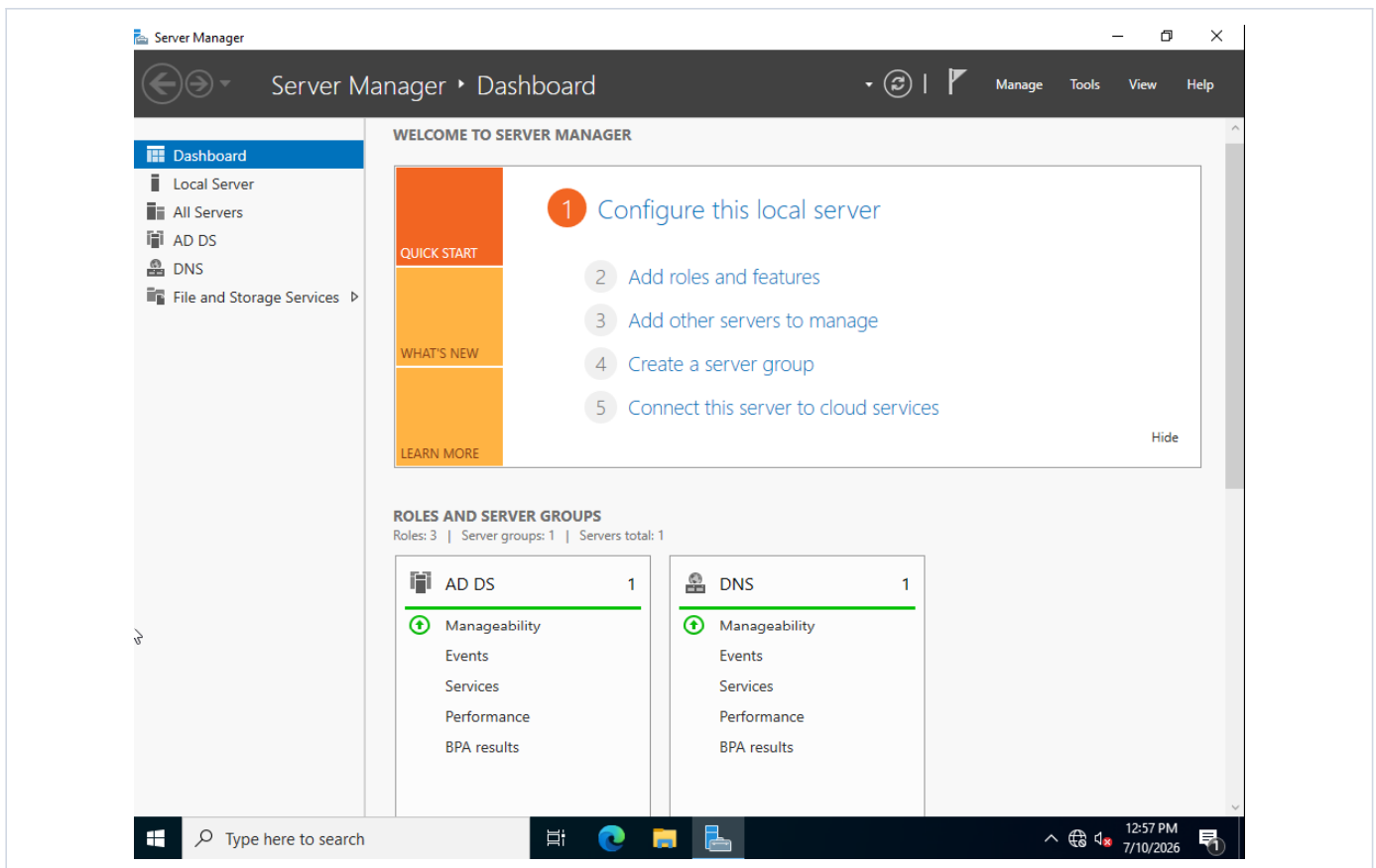


Figure 3: DC01 successfully promoted — AD DS and DNS roles active in Server Manager.

Windows 11 was then joined to the labcorp.local domain, using DC01 as its DNS server to ensure proper name resolution for the domain join and subsequent Kerberos authentication.

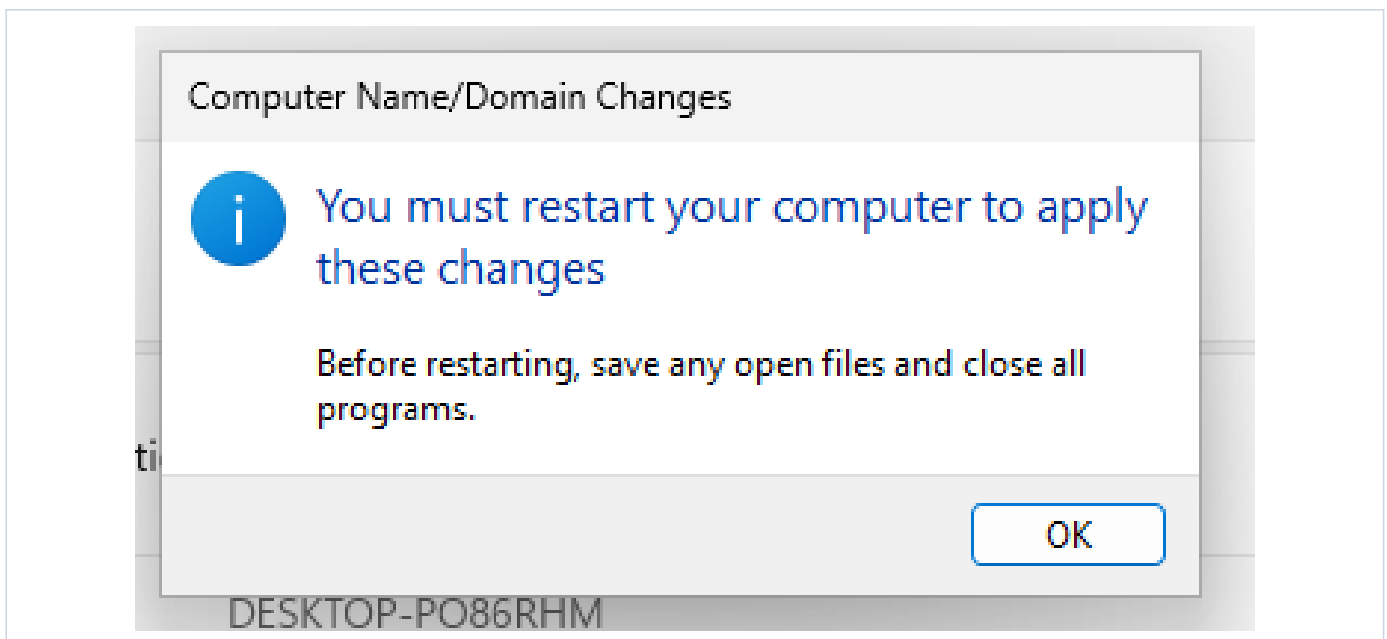


Figure 4: Windows 11 successfully joined to the labcorp.local domain.

Two domain accounts were created inside a dedicated LabAccounts Organizational Unit: a standard low-privilege user (janalyst) and a service account (svc_sql).

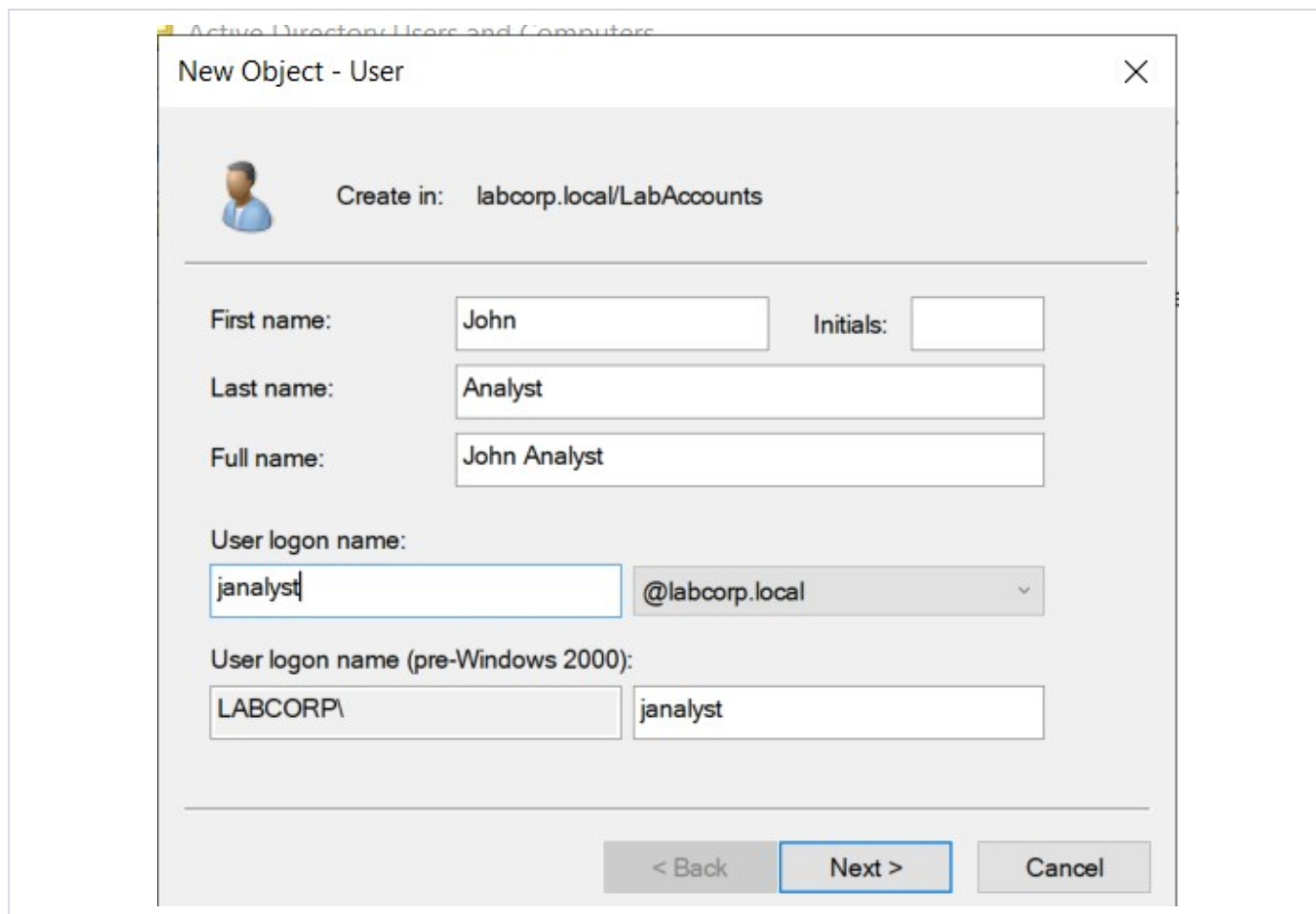


Figure 5: Standard domain user 'janalyst' created in Active Directory Users and Computers.

An SPN was manually registered on the svc_sql account to simulate a SQL Server service running under a domain account — a widespread real-world misconfiguration that makes an account Kerberoastable:

```
C:\Users\Administrator>setspn -A MSSQLSvc/dc01.labcorp.local:1433 labcorp\svc_sql
Checking domain DC=labcorp,DC=local
Registering ServicePrincipalNames for CN=SQL
Service,OU=LabAccounts,DC=labcorp,DC=local
MSSQLSvc/dc01.labcorp.local:1433
Updated object

C:\Users\Administrator>setspn -L svc_sql
Registered ServicePrincipalNames for CN=SQL
Service,OU=LabAccounts,DC=labcorp,DC=local:
MSSQLSvc/dc01.labcorp.local:1433
```

4. Telemetry Pipeline

Sysmon (SwiftOnSecurity configuration) was deployed on DC01 for enhanced process and system telemetry. The Splunk Universal Forwarder was then installed to ship both the Windows Security event log and the Sysmon operational log to the Splunk indexer running on the host machine, over TCP port 9997.

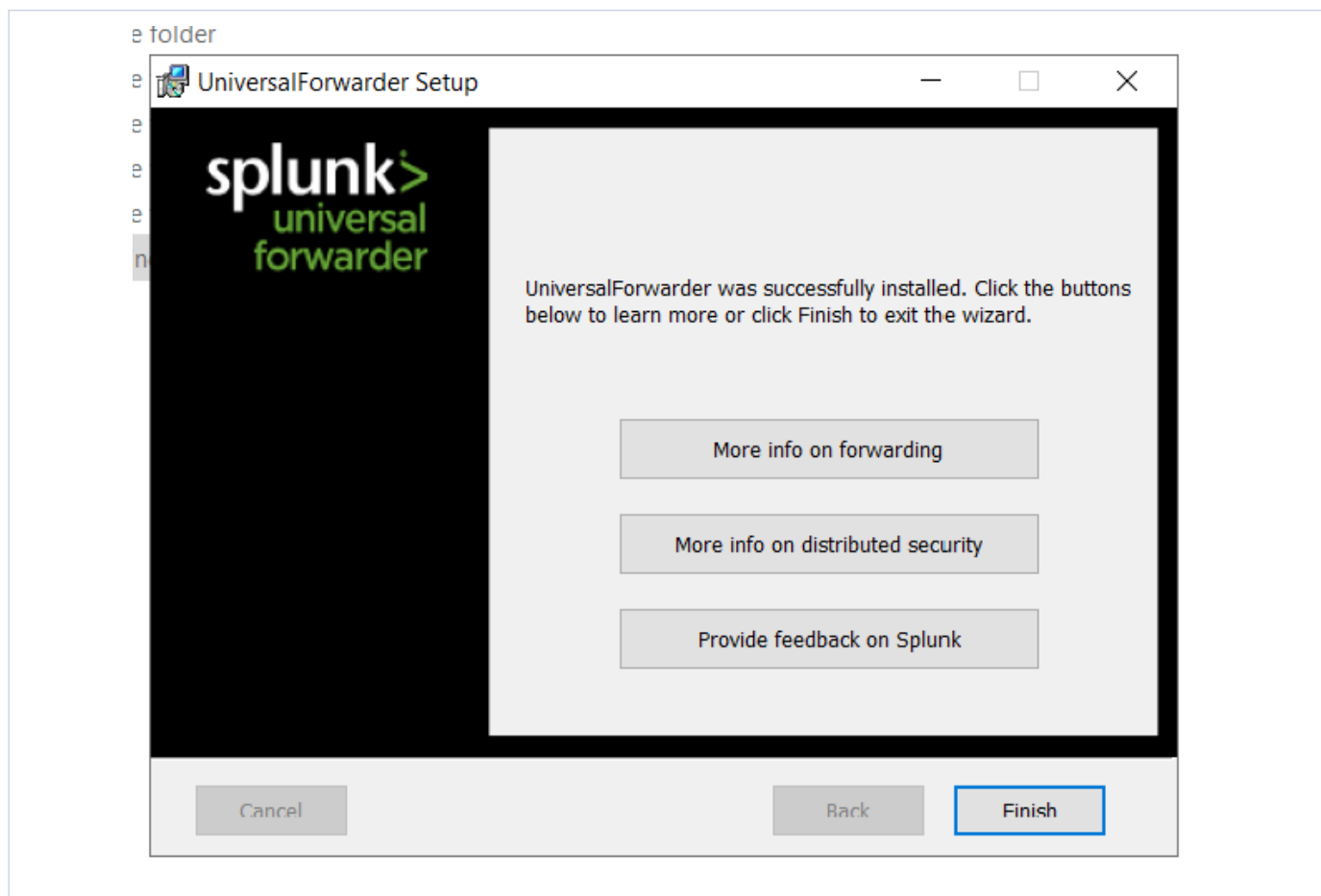


Figure 6: Splunk Universal Forwarder installed successfully on DC01.

Network connectivity from DC01 to the Splunk receiving port was validated directly:

```
PS C:\> Test-NetConnection -ComputerName 192.168.100.1 -Port 9997

ComputerName      : 192.168.100.1
RemoteAddress     : 192.168.100.1
RemotePort        : 9997
InterfaceAlias    : Ethernet0
SourceAddress     : 192.168.100.10
TcpTestSucceeded  : True
```

```
PS C:\Users\Administrator> Test-NetConnection -ComputerName 192.168.100.1 -Port 9997

ComputerName      : 192.168.100.1
RemoteAddress     : 192.168.100.1
RemotePort        : 9997
InterfaceAlias    : Ethernet0
SourceAddress     : 192.168.100.10
TcpTestSucceeded  : True
```

Figure 7: TCP connectivity confirmed between DC01 and the Splunk indexer on port 9997.


```
[~] CCache file is not found. Skipping...
$krb5tgs$23$*svc_sql$LABCORP.LOCAL$labcorp.local/svc_sql*$973061ea7ae038472e49748613
f80b6c$....
(truncated – full RC4-encrypted TGS hash captured, ready for offline cracking)
```

The attack succeeded: a valid TGS ticket for svc_sql was extracted, encrypted with RC4 (etype 23 / 0x17). This ticket is now suitable for offline password cracking via hashcat or John the Ripper, without any further interaction with the domain controller — the core reason Kerberoasting is such a dangerous, low-noise technique in real environments.

6. Splunk Detection

The attack generated Windows Security Event ID 4769 (Kerberos Service Ticket Operations) on DC01, which was forwarded into Splunk in real time. A total of 41 Event ID 4769 events were captured over the observation window, representing a mix of legitimate domain Kerberos traffic and the single attack request.

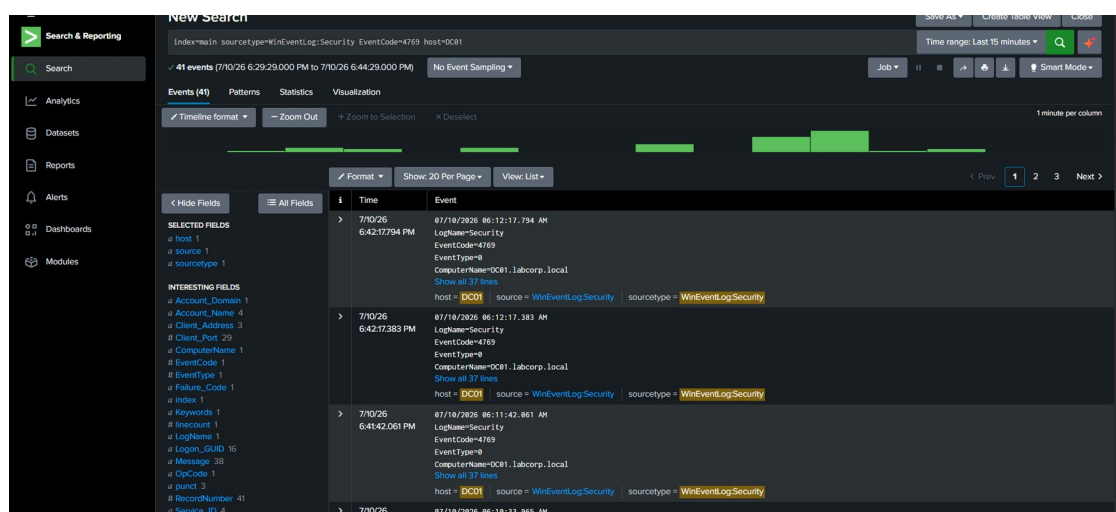


Figure 9: All Event ID 4769 events captured in Splunk following the attack.

Inspecting an individual event confirmed Splunk correctly parses the Ticket_Encryption_Type field — the detection signal. Legitimate modern Kerberos traffic uses AES (0x12 or 0x11); Kerberoasting tooling requests RC4 (0x17) by default, since it is far weaker and faster to crack offline.

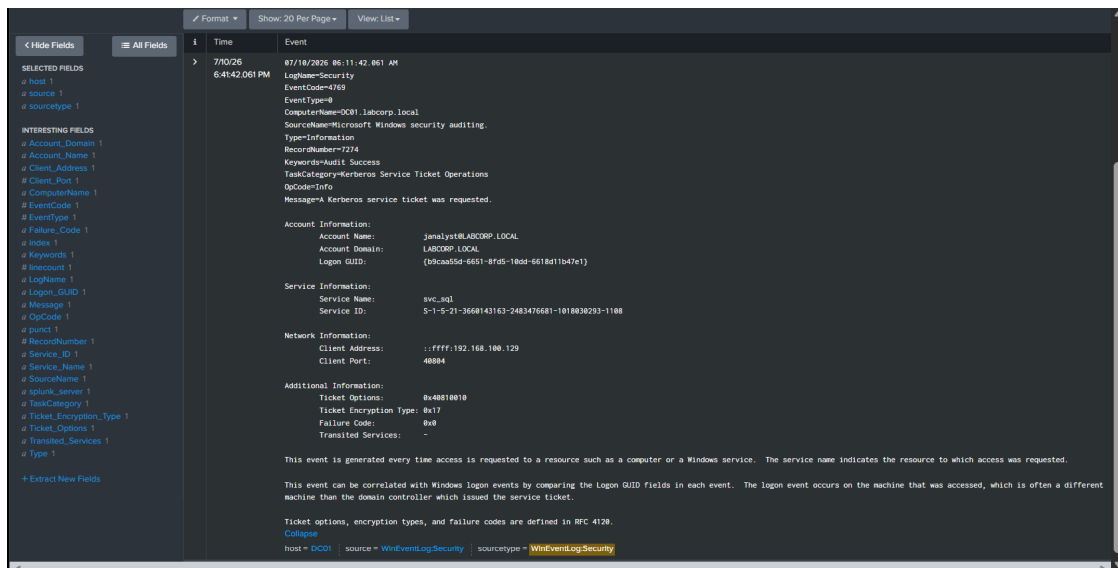


Figure 10: Expanded Event ID 4769 showing `Account_Name=janalyst`, `Service_Name=svc_sql`, `Client_Address=192.168.100.129` (Kali), and `Ticket_Encryption_Type=0x17`.

6.1 Detection Search

```
index=main sourcetype=WinEventLog:Security EventCode=4769
Ticket_Encryption_Type=0x17
| table _time, Account_Name, Service_Name, Client_Address, Ticket_Encryption_Type
```

This query isolates the single RC4-encrypted ticket request out of the 41 total Event ID 4769 events, cleanly separating the attack from routine Kerberos traffic.

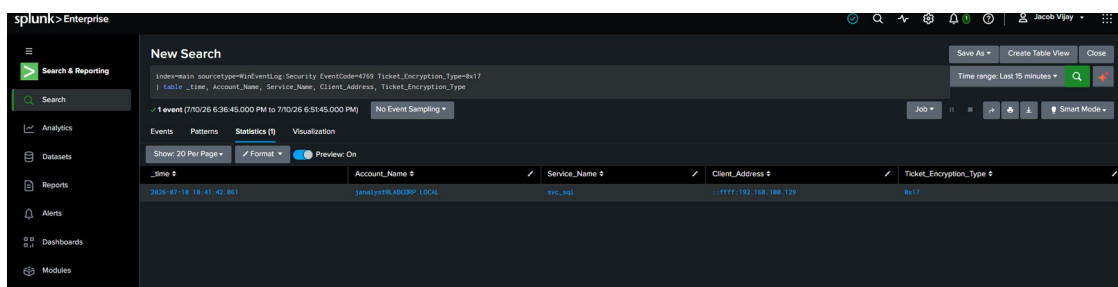


Figure 11: Detection query results — the Kerberoasting attempt isolated, showing the compromised account, targeted service, and attacker source IP.

7. Dashboard and Scheduled Alert

The detection query was saved as a dashboard panel for at-a-glance SOC visibility, and as a scheduled alert to simulate real-time monitoring.

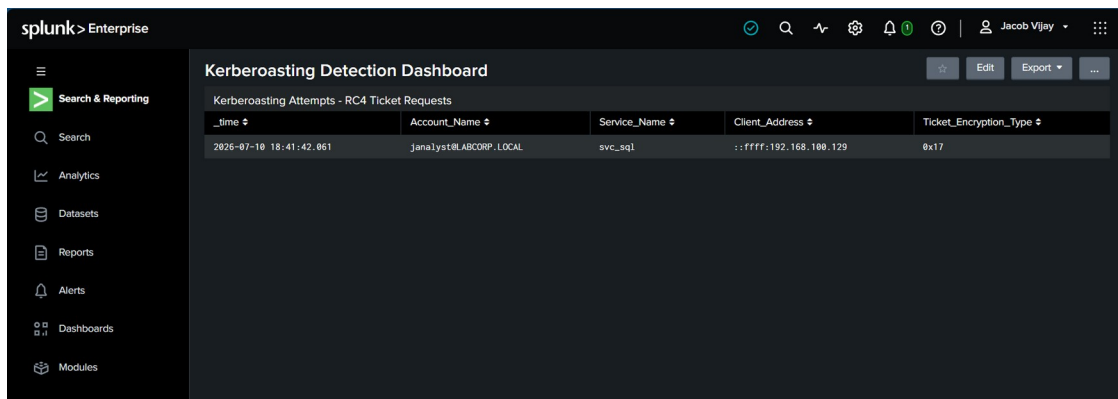


Figure 12: Kerberoasting Detection Dashboard, showing the isolated attack event.

A scheduled alert was configured to run every 5 minutes (cron: `* /5 * * * *`), triggering whenever the detection query returns more than zero results — simulating the alert that would page a SOC analyst in a live environment.

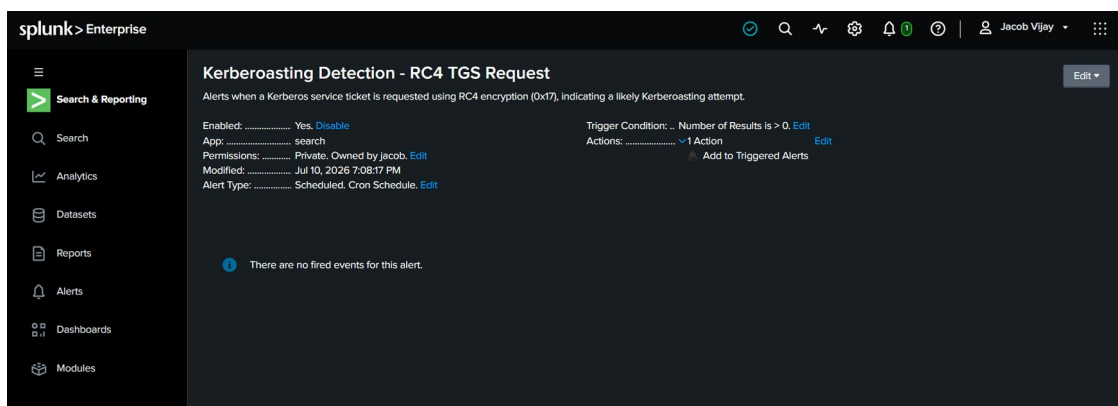


Figure 13: Scheduled alert 'Kerberoasting Detection - RC4 TGS Request' enabled and active.

8. Detection Refinement and Limitations

8.1 Reducing False Positives

A single RC4-encrypted TGS request is a strong signal in this lab, but in mixed real-world environments it can occasionally be triggered by legitimate but outdated systems. Known sources of false positives include:

- Legacy applications or printers that only support RC4 encryption and have not been upgraded to support AES
- Misconfigured service accounts where `msDS-SupportedEncryptionTypes` was never set to AES-only
- Older domain controllers or clients (pre-Windows Server 2008) still present in a domain's compatibility tail

Because of this, a production version of this detection should be tuned with a short allow-list of known-legitimate RC4 service accounts, reviewed periodically as systems are upgraded.

8.2 A Stricter, Higher-Fidelity Detection

The current query alerts on any single RC4 ticket request, which is appropriate for a lab but can be noisy in a large environment with legacy systems. A more mature detection would add a behavioral threshold layer on top of the encryption-type filter, for example:

```
index=main sourcetype=WinEventLog:Security EventCode=4769
Ticket_Encryption_Type=0x17
| stats count dc(Service_Name) as unique_spns_requested values(Service_Name) as
targets by Account_Name, Client_Address
| where unique_spns_requested >= 3
```

This variant flags an account only when it requests RC4 tickets for three or more distinct SPNs in a short window — the classic signature of a Kerberoasting tool enumerating every SPN in the domain, rather than a single legacy application quietly using RC4 for one known service. This significantly reduces noise while preserving detection of the actual attack pattern.

8.3 Offline Cracking (Attacker's Next Step)

To fully illustrate attacker payoff, the extracted TGS hash can be taken offline and cracked with hashcat, without any further contact with the domain controller — this is what makes Kerberoasting so dangerous and low-noise in practice:

```
hashcat -m 13100 -a 0 svc_sql_ticket.txt rockyou.txt

# -m 13100 : Kerberos 5 TGS-REP etype 23 (RC4) hash mode
# -a 0      : straight/dictionary attack
# If the service account's password is present in the wordlist,
# hashcat recovers it in plaintext with no further domain interaction.
```

This step was intentionally not run against a real password in this lab to avoid embedding a crackable credential in a public repository. In a professional engagement, a successful crack at this stage would be reported as full compromise of the service account, with the recommendation to rotate its password immediately and migrate it to a Group Managed Service Account.

8.4 Lab Cleanup and Teardown

Before re-running or sharing this lab, the following steps keep the environment reusable and prevent state (event logs, ticket caches, DC promotion) from carrying over between demonstrations:

- Snapshot each VM (DC01, Windows 11, Kali) immediately after initial setup, before running the attack, so the environment can be reset to a clean pre-attack state for repeat demos or interviews
- Clear the Kerberos ticket cache on Kali between attack runs: `klist purge`
- Rotate or reset the `svc_sql` and `janalyst` passwords if the lab is rebuilt for a public demonstration
- Revert to the pre-attack snapshot rather than manually cleaning up Splunk indexes, to keep the detection data consistent with the documented walkthrough

9. Conclusion

This lab successfully demonstrated the full lifecycle of a Kerberoasting attack and its detection: from building a realistic Active Directory environment with a deliberately vulnerable service account, executing the attack using

real offensive tooling (Impacket), through to building a working Splunk-based detection, dashboard, and scheduled alert.

9.1 Key Takeaways

- Kerberoasting requires no elevated privileges — any valid domain account can request TGS tickets for SPN-registered accounts, making it a common and dangerous post-compromise technique.
- RC4 ticket encryption (etype 0x17) is a strong, low-noise detection signal since legitimate modern Windows environments predominantly use AES.
- Domain Controllers do not use the local SAM database, so standard local-group permission fixes for services (e.g. Event Log Readers) do not apply — Local System is the more reliable choice for forwarders on DCs.
- Clock synchronization is critical in isolated lab networks: Kerberos has a strict 5-minute skew tolerance, and mismatched search time ranges in Splunk can mask fully functional data pipelines.

9.2 Mitigation Recommendations

- Enforce AES-only Kerberos encryption via Group Policy (msDS-SupportedEncryptionTypes) to eliminate RC4 ticket issuance
- Use Group Managed Service Accounts (gMSAs) for service accounts, which have long, automatically-rotated passwords resistant to offline cracking
- Monitor and alert on Event ID 4769 with RC4 encryption type as a standing detection rule
- Regularly audit AD for accounts with unnecessary SPNs registered